요구사항 명세서(SRS) 초안

논문-5: CP-ABE 기반 금융 데이터 보안 및 기업가치 보호 시스템

Data Security and Firm Value: CP-ABE Analysis and Methods

1. 문서 정보

문서명	[프로젝트명] 요구사항 명세서(SRS)
버전	v0.1
작성일	2026-04-04
작성자	[이름]
대상	논리 설계 + 시뮬레이션 기반 평가

2. 용어/약어

CP-ABE	Ciphertext-Policy Attribute-Based Encryption — 암호문 정책 속성 기반 암호화
Access Tree	CP-ABE에서 암호화 정책을 표현하는 트리 구조 (AND/OR/Threshold 게이트)
MSK (Master Secret Key)	인증 기관이 생성하는 마스터 비밀키 — KeyGen에 사용
PK (Public Key)	시스템 공개키 — 암호화에 사용
SK (Secret Key)	사용자 속성 집합 기반으로 생성된 비밀키 — 복호화에 사용
Bilinear Map	쌍선형 사상 — CP-ABE의 수학적 기반 (e: G0 x G0 → G1)
BLE Beacon	Bluetooth Low Energy 비콘 — 위치 기반 로그인에 사용
Nonce	일회용 난수 — 재전송 공격 방지
c-nonce	클라이언트 난수 — 대칭키로 활용되는 세션 식별자
MyData / PDS	개인 데이터 저장소 — 정보주체 중심 데이터 관리 모델
CAR (Cumulative Abnormal Return)	누적 비정상 수익률 — 개인정보 유출이 주가에 미치는 영향 측정

망분리	금융보안원 지침 — 업무망과 인터넷망을 물리적/논리적으로 분리하는 규제

3. 목표 및 성공 기준

3.1 목표

- G1: CP-ABE 기반 금융 데이터 암호화·접근 제어 모델(절차/수학적 구조)을 설계한다.
- G2: BLE 비콘 + CP-ABE 결합 위치 기반 금융 로그인·키 교환 방안을 명세한다.
- G3: 개인정보 유출이 기업가치(주가·CAR)에 미치는 영향을 분석하고 보안 투자 근거를 제시한다.
- G4: MyData/PDS 기반 정보주체 중심 금융 데이터 관리 모델을 명세한다.

3.2 성공 기준

- SC-01: CP-ABE Setup→KeyGen→Encrypt→Decrypt 4 단계 흐름을 수식 없이 논리적으로 명세한다.
- SC-02: BLE 비콘 로그인 시나리오에서 재전송 공격(Replay Attack) 방어 절차를 명세한다.
- SC-03: 개인정보 유출 사고 공시 후 주가 비정상 수익률(CAR) 분석 결과를 비교표로 제시한다.
- SC-04: 망분리 규제 완화 조건 및 MyData 도입 요건을 체크리스트로 제시한다.

4. 범위

In-scope

- CP-ABE 4 단계 알고리즘(Setup/KeyGen/Encrypt/Decrypt) 논리 설계
- BLE 비콘 + CP-ABE 위치 기반 금융 로그인 흐름
- 개인정보 유출의 기업가치 영향 분석(주가 비정상 수익률, 정보전이효과)
- MyData/PDS 기반 금융 데이터 주권 모델, 망분리 규제 준수 설계

Out-of-scope

- CP-ABE 수학적 완전 구현(쌍선형 사상 연산 코드), BLE 하드웨어 구현
- 실제 주식시장 데이터 수집 및 CAR 실측

5. 시스템 개요(논리 아키텍처)

구성요소

- 사용자(금융 고객/직원) — 스마트폰/단말 (BLE 수신)
- 인증 기관(Attribute Authority, AA) — MSK·PK 생성, SK 발급
- BLE 비콘 노드 — nonce 브로드캐스트, 위치 기반 접근 정책 배포
- 금융 데이터 서버 — CP-ABE 암호화된 데이터 저장·제공
- MyData 플랫폼 — 정보주체 동의 기반 데이터 이동·관리

데이터 항목 정의(최소)

- D1: 사용자 속성 집합(직급, 위치, 자격, 소속), SK(속성 기반 비밀키)
- D2: 암호문(Access Tree 내재), 비콘 nonce, c-nonce
- D3: 접근 이벤트 로그(복호화 시도, 성공/실패, 위치)

6. 요구사항 우선순위 규칙

등급	레이블	설명
P0	Must	없으면 시스템 성립 불가
P1	Should	성능/완성도에 중요
P2	Could	있으면 좋음(부가)

7. 기능 요구사항(FR)

FR-01: CP-ABE 키 생성 및 관리	
우선순위	P0
설명	시스템은 인증 기관(AA)이 마스터 키(MSK)와 공개키(PK)를 생성하고, 사용자 속성 집합(S)에 기반한 비밀키(SK)를 발급해야 한다.
근거(Rationale)	SK 없이 CP-ABE 복호화 불가 — 금융 데이터 접근 제어의 전제.
입력(Input)	사용자 ID, 속성 집합(직급·위치·자격), AA 마스터 키

처리(Process)	Setup: MSK·PK 생성; KeyGen: 속성 기반 SK 생성 및 사용자에게 안전 전달
출력(Output)	사용자별 SK, PK 공개, MSK 비공개 유지
예외/오류	속성 오류, 키 만료, 속성 위조 시도
검증(Verification)	발급된 SK로 해당 속성 정책을 만족하는 암호문 복호화 성공 여부

FR-02: CP-ABE 금융 데이터 암호화	
우선순위	P0
설명	시스템은 금융 데이터를 CP-ABE Access Tree 정책과 함께 암호화하여 저장해야 한다.
입력(Input)	금융 데이터(메시지 M), 접근 정책(Access Tree T), PK
처리(Process)	Access Tree의 루트에 임의값 할당, 하위 노드에 다항식 분산; 암호문(CT) 생성
출력(Output)	CT (Access Tree 내재된 암호문), 스토리지 저장
예외/오류	Access Tree 설정 오류, PK 불일치
검증(Verification)	정책을 만족하는 사용자만 복호화 가능하고, 불만족 사용자는 불가한지

FR-03: CP-ABE 금융 데이터 복호화 및 접근 제어	
우선순위	P0
설명	시스템은 사용자 속성 집합이 Access Tree 정책을 만족할 때만 복호화를 허용해야 한다.
입력(Input)	사용자 SK, 암호문 CT
처리(Process)	재귀 알고리즘으로 Access Tree 만족 여부 검사; 쌍선형 사상 특성으로 복호화
출력(Output)	복호화된 메시지 M (정책 만족 시) / 접근 거부 (불만족 시)
예외/오류	속성 부족, 키 만료, 정책 불일치
검증(Verification)	정책 만족 사용자: 복호화 성공, 불만족 사용자: 복호화 실패 검증

FR-04: BLE 비콘 + CP-ABE 위치 기반 금융 로그인	
우선순위	P0

설명	시스템은 BLE 비콘이 브로드캐스트하는 CP-ABE 암호화된 nonce를 활용하여, 적합한 속성을 가진 사용자만 위치 기반 간편 로그인을 수행할 수 있어야 한다.
입력(Input)	BLE 비콘 신호(CP-ABE 암호화된 nonce), 사용자 SK
처리(Process)	비콘 신호 수신 → SK로 nonce 복호화 → nonce+비밀번호 해시 → c-nonce 생성 → 서버 전송·검증
출력(Output)	로그인 성공/실패, 세션 키
예외/오류	비콘 범위 이탈, nonce 만료, 속성 불만족
검증(Verification)	재전송 공격(이전 nonce 재사용) 시 로그인 실패 처리되는지

FR-05: 개인정보 유출 사고 영향 분석 모듈	
우선순위	P1
설명	시스템은 금융 기관의 개인정보 유출 사고 발생 시 주가 비정상 수익률(CAR) 및 정보전이효과를 분석하는 기능을 제공해야 한다.
입력(Input)	유출 사고 공시 일정, 기업 주가 데이터(사고 전후)
처리(Process)	CAR 산출(사고 당일+익일 비정상 수익률 합산); 성장기회 지표·유출 유형별 분석
출력(Output)	기업별 CAR 분석표, 정보보안 기업 주가 연동 효과(반사이익)
검증(Verification)	유출 규모·성장기회가 클수록 CAR 음수 폭이 큰지 시나리오 검증

FR-06: MyData/PDS 기반 금융 데이터 주권 관리	
우선순위	P1
설명	시스템은 정보주체(고객)가 자신의 금융 데이터 제공 범위를 직접 설정하고 제3자 제공 여부를 결정할 수 있어야 한다.
입력(Input)	정보주체 ID, 데이터 제공 동의 항목, 수신 기관 목록
처리(Process)	PDS에 동의 정보 기록; 동의된 항목만 제3자(핀테크) 전달; 동의 철회 즉시 반영
출력(Output)	데이터 제공 현황 조회, 동의 이력
예외/오류	동의 없는 접근 시도, 데이터 범위 초과 요청
검증(Verification)	동의 철회 후 해당 기관의 데이터 접근이 즉시 차단되는지

FR-07: 망분리 규제 준수 설계	
우선순위	P0
설명	시스템은 금융보안원 망분리 지침을 준수하며, 연구·개발망 예외 조건 및 악성 코드 점검 절차를 설계에 포함해야 한다.
입력(Input)	업무망/인터넷망 분리 정책, R&D 예외 적용 항목
처리(Process)	업무망-인터넷망 분리 설계; R&D망 예외 적용 시 소스코드 유출 방지·가명정보 지침 적용; 악성코드 점검 절차 명세
출력(Output)	망분리 준수 체크리스트, 예외 적용 근거
검증(Verification)	규제 체크리스트 항목별 충족 여부 검토

FR-08: 재전송 공격 방지 및 세션 보안	
우선순위	P0
설명	시스템은 BLE 비콘 nonce 주기적 갱신 및 c-nonce를 통해 재전송 공격을 방지해야 한다.
입력(Input)	비콘 nonce(주기적 갱신), c-nonce(세션별 생성)
처리(Process)	nonce 유효시간 내 재사용 차단; c-nonce를 대칭키로 해시값 암호화; 서버에서 현재 nonce 기준으로 검증
출력(Output)	정상 로그인 성공, 이전 nonce 재사용 시 실패
예외/오류	nonce 만료 시 재로그인 요구
검증(Verification)	이전 세션 캡처 데이터로 재로그인 시도 시 반드시 실패 처리되는지

8. 비기능 요구사항(NFR)

NFR-01: 암호화 성능(처리 지연)	
우선순위	P0
설명	CP-ABE 암호화/복호화 지연을 속성 수·Access Tree 복잡도별로 분석하여 금융 서비스 허용 범위 내임을 검증해야 한다.

검증(Verification)	속성 수 증가에 따른 복호화 지연 증가 폭이 정의되어 있는지

NFR-02: 확장성(구독자 수 증가)	
우선순위	P0
설명	구독자(사용자) 수가 증가해도 통신 지연 증가 폭이 최소화되어 IoT·금융 환경의 확장성을 지원해야 한다.
검증(Verification)	구독자 수 증가 시나리오(최소 2개)에서 지연 증가 폭이 정의되어 있는지

NFR-03: 키 관리 효율성	
우선순위	P0
설명	사용자는 속성이 포함된 하나의 SK만으로 다수의 암호문을 복호화할 수 있어야 하며, 키 관리 부담이 최소화되어야 한다.
검증(Verification)	단일 SK로 복수의 정책 만족 암호문 복호화 성공 여부

NFR-04: 보안 — 재전송 공격 방지	
우선순위	P0
설명	BLE 비콘 nonce 기반 로그인에서 이전 세션의 캡처 데이터로 재로그인 공격이 차단되어야 한다.
검증(Verification)	재전송 공격 시나리오에서 로그인 실패가 명확히 처리되는지

NFR-05: 금융 규제 및 기업가치 준수	
우선순위	P1
설명	설계는 GDPR, 한국 개인정보보호법, 금융보안원 망분리 지침을 준수하고, 개인정보 유출이 기업가치에 미치는 위험을 설계 단계에서 최소화해야 한다.
검증(Verification)	규제 준수 체크리스트 및 CAR 영향 최소화 설계 근거가 문서화되어 있는지

9. 가정/제약

- A1: CP-ABE 인증 기관(AA)은 신뢰된 제 3 자 환경을 가정한다.
- A2: BLE 비콘은 안전한 물리적 환경에 설치되어 있음을 가정한다.
- A3: 실제 수학적 연산 구현 없이 논리 흐름·지연 모델 기반 시뮬레이션으로 평가한다.
- A4: 주가 영향 분석은 실증 데이터 대신 시나리오 기반으로 평가한다.

10. 검증/테스트/평가 계획

- EV-01: CP-ABE 4 단계 흐름(Setup→KeyGen→Encrypt→Decrypt) 논리 일관성 검증
- EV-02: 속성 수·Access Tree 복잡도별 복호화 지연 분석 (성능 목표 달성 여부)
- EV-03: BLE 비콘 위치 기반 로그인 시나리오 — 정상 로그인 및 재전송 공격 방어 검증
- EV-04: 개인정보 유출 CAR 시나리오 (성장기회 대소별, 유출 유형별 비교)
- EV-05: MyData 동의 철회 시 즉각 접근 차단 검증
- EV-06: 망분리 규제 준수 체크리스트 항목별 충족 여부 검토

부록 A. 자료조사 요약(요구사항 근거)

요구사항	근거 (자료조사 요약)
FR-02/03 근거	CP-ABE는 Access Tree에 정책을 내재시켜 데이터 단위 암호화 접근 제어 가능 — 금융 데이터 민감도 대응에 적합
FR-05 근거	개인정보 유출 사고 공시 당일·익일 주가 평균 약 1.2% 하락 (CAR 음수) — 보안 투자의 기업가치 보호 근거
NFR-05 근거	망분리 완화와 MyData 도입은 혁신과 보안의 균형 — 소스코드 유출 방지·가명정보 지침 준수가 전제